Relatório de Auditoria de Segurança

Agente Storyteller - aplicação receptora da credencial

19/10/2026

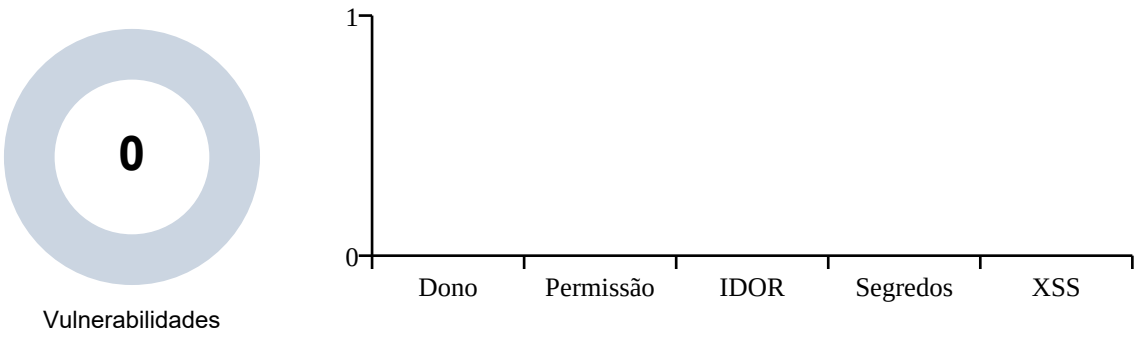
Aplicação receptora da credencial: console Windows, supervisor temporário, lançador PowerShell, fila local e adaptador OpenAI Responses. Sem acesso à chave real, clipboard, ambiente/memória do processo ou arquivos .env.

Python 3, PowerShell, console Windows/msvcrt, subprocess, HTTPX e Pydantic. O jogo usa React/FastAPI/SQLite, mas não é a superfície receptora auditada. Não há rotas HTTP nem frontend web nesta aplicação receptora.

Três falhas locais verificadas e corrigidas nas fontes. Zero vulnerabilidades exploráveis remotamente demonstradas neste escopo. A causa da tentativa real anterior permanece inconclusiva; colagem duplicada não foi confirmada na chave real.

Resumo e classificação

0 vulnerabilidades de segurança demonstradas. 3 achados informativos de funcionamento/UX corrigidos. Informativos não entram na contagem de vulnerabilidades; o ambiente real não foi certificado.



Paleta de severidade: crítica #B91C1C; alta #EA580C; média #D97706; baixa #2563EB; informativa #64748B. Não há fatias artificiais para categorias com zero achados de segurança.

Cobertura e limites por categoria

Categoria	Resultado e evidência
Isolamento de dono/tenant	Não aplicável como multi-tenant - Console local sem banco de usuários nem API exposta. Arquivos da fila pertencem ao contexto local; processos com acesso equivalente ao host estão fora de uma fronteira de cofre.
Autorização no servidor	Protegido no worker local - Sem gate apenas visual: flags de aprovação, alvo, teto, hashes, latch e prazo são verificados antes do envio e após preflight. Aprovação humana é registrada pelo agente, não inferida pelo worker.
IDOR	Não aplicável como rota HTTP; paths auditados - Número de lote tipado, sem comando/path arbitrário; resolução dos arquivos congelados deve ficar dentro da raiz. Não há handlers HTTP nesta superfície.
Segredos	Proteções verificadas com limites - Sem valor real examinado. Sem persistência programática de chave, sem argumentos com chave, sem chave no preflight. Ambiente só do filho. Não garantir zeroização de RAM/pagefile/dumps do SO.
XSS / injeção no output	XSS não aplicável; console verificado - Sem HTML/JS. Conteúdo digitado nunca é escrito no terminal; somente asteriscos/contagem e mensagens fixas, impedindo eco de escape/control. Pedidos não viram comandos arbitrários.

Proteções verificadas

- Expiração UTC e monotônica; expiração/interrupção mata e recolhe avaliador ativo.
- Manifesto e implementação revalidados após preflight e antes da credencial no filho.
- Pedido consumido uma vez, latch e memória de lotes impedem repetição silenciosa.
- Credencial não aparece em argumentos, status ou preflight; conteúdo real não foi lido.
- Correção visual falha fechada sem console interativo; não usa clipboard nem eco plaintext.

Scan delimitado: 10 arquivos, 2 blobs históricos, 0 handlers HTTP. Indicadores são metadados mascarados; classificação não é validação de credencial.

Achados por arquivo e linha atual

ID / severidade	Arquivo:linha atual	Descrição
KEY-001 / informativa	scripts/luna_credential_supervisor.py:31	Entrada sem feedback e sem validação estrutural
KEY-002 / informativa	scripts/evaluate_openai_luna_low_live.py:61	Falhas locais, rede e JSON agrupadas no mesmo código
KEY-003 / informativa	scripts/evaluate_openai_luna_low_live.py:172	Ramo de credencial vazia referenciava fase inexistente

Linhas atuais apontam a correção. A descrição anterior foi observada antes da edição nesta tarefa, sem commit intermediário; não representa trecho vulnerável ainda presente.

KEY-001 - Entrada sem feedback e sem validação estrutural

Antes: O console usava getpass e verificava apenas se key.strip() era não vazio. O operador não via quantidade de caracteres, duplicata ou controles de colagem.

Condição: Operador cola duas vezes o mesmo token, ou o terminal entrega Ctrl+V como controle em vez do texto. A presença desse evento na entrada real não foi inspecionada.

Impacto: Falha local, tentativa desnecessária, diagnóstico ambíguo e dificuldade de correção. Nenhum vazamento de chave foi demonstrado.

Correção: Editor mascarado com asteriscos e contador só na tela, Backspace, Esc/Ctrl+U, cancelamento, limite de buffer e validação. Repetição integral de token sk- duas a quatro vezes é recusada; espaços, Unicode e controles são recusados. Nunca ler clipboard, revelar fragmentos ou dividir automaticamente a chave.

Evidência: read_credential; credential_problem em scripts/evaluate_openai_luna_low_live.py:46; bloqueio do supervisor antes de subprocess em scripts/luna_credential_supervisor.py:167.

Estado: Corrigido nas fontes; ativação requer reinício e entrada protegida humana

KEY-002 - Falhas locais, rede e JSON agrupadas no mesmo código

Antes: HTTPError e ValueError eram normalizados como transport_or_response_invalid, sem subtipo suficiente para diagnóstico.

Condição: Cabeçalho local inválido, falha de conexão/timeout/protocolo ou resposta JSON inválida.

Impacto: Não distinguir falha local de falha remota; risco operacional de pedir outra chave ou repetir chamada sem causa conhecida. Não constitui, isoladamente, vulnerabilidade de autorização.

Correção: Classificação só pelo tipo da exceção, sem texto potencialmente secreto. Separar protocolo local, conexão, timeout, protocolo remoto, requisição local, I/O e parsing/forma do JSON. Preservar códigos HTTP 401/403/429/5xx.

Evidência: transport_error_code:61; response_json_invalid:209; response_shape_invalid:215. Testes MockTransport fazem exceções conterem texto sintético sensível e confirmam que ele não aparece no erro normalizado.

Estado: Corrigido e verificado offline

KEY-003 - Ramo de credencial vazia referenciava fase inexistente

Antes: OperationPhase.AUTHENTICATION não existe no enum do contrato; o ramo de credencial vazia produzia AttributeError em vez do erro controlado.

Condição: Entrada vazia chegando diretamente ao adaptador, ou entrada malformada interceptada no novo ramo.

Impacto: Erro local sem diagnóstico contratual; nenhuma chamada necessária para reproduzir. Não comprova vazamento de credencial.

Correção: Usar OperationPhase.VALIDATION; categoria de autenticação e códigos credential_missing/credential_input_invalid sem material secreto.

Evidência: api/llm/contract.py:91 define as fases; scripts/evaluate_openai_luna_low_live.py:172 usa fase válida após correção.

Estado: Corrigido e verificado offline

Verificação, recomendações e limitações

• Entrada e erros reproduzidos com valores exclusivamente sintéticos e transportes mockados; nenhuma chamada paga nesta auditoria.

• h11 reproduziu rejeição local de cabeçalho com caractere de controle, sem socket; compatibilidade com hipótese anterior não prova causa real.

• Console Windows PTY exibiu asteriscos e contador e retornou SYNTHETIC_CONSOLE_CHECK_OK; nenhum valor real foi usado.

• 73 testes focados aprovados antes da ampliação; 126 testes relacionados aprovados ao final, incluindo editor, supervisora, custo, adaptador, gates históricos isolados e integração de campanha. Um aviso preexistente python_multipart. XML eval-results/credential-input-audit-extended-2026-10-19.xml. Suíte integral não executada.

• P1: reiniciar a sessão com a versão corrigida quando o humano puder inserir a chave; até lá manter gates de envio fechados.

• P1: não inferir colagem duplicada na chave real nem pedir sua exibição; nunca reconstruir/corrigir o segredo automaticamente.

• P2: em próxima chamada especificamente autorizada, usar os novos códigos seguros de diagnóstico e mostrar custo final; nenhum retry nesta auditoria.

• P3: preservar hashes e recibos antigos; preparar novos manifestos para código alterado. Não atualizar hashes históricos para fazê-los passar.

• Não é auditoria integral de React/FastAPI/SQLite nem certificação. Escopo restrito à aplicação receptora, adaptador e lançadores de credencial.

• A chave real, seu comprimento, duplicação, conteúdo, clipboard e memória/ambiente do processo ativo não foram inspecionados; validade no provedor continua desconhecida.

• A versão antiga da supervisora está carregada no processo existente. Mudar fonte não modifica suas funções em memória; ativação exige reinício e uma entrada protegida humana. Não encerrar sem coordenação enquanto o usuário está fora.

• Formato estrutural não prova autenticação. Não se impõe comprimento fixo nem se assume formato completo futuro das chaves do provedor.

• Sem rede real, CVE scan ou análise de todo histórico/bundle do produto. Histórico examinado apenas para os arquivos explicitamente no escopo. Relatório anterior preservado.

ISSUES PARA O GITHUB

Rascunhos de rastreabilidade de achados informativos já corrigidos; não foram publicados e não alegam vulnerabilidade remota.

--- ISSUE 1 ---
[Segurança] Entrada sem feedback e sem validação estrutural
Labels sugeridas: security, informativa

Estado: corrigido nas fontes; rascunho não publicado.

Problema: O console usava getpass e verificava apenas se key.strip() era não vazio. O operador não via quantidade de caracteres, duplicata ou controles de colagem.
Condição: Operador cola duas vezes o mesmo token, ou o terminal entrega Ctrl+V como controle em vez do texto. A presença desse evento na entrada real não foi inspecionada.
Impacto: Falha local, tentativa desnecessária, diagnóstico ambíguo e dificuldade de correção. Nenhum vazamento de chave foi demonstrado.
Evidência atual: scripts/luna_credential_supervisor.py:31. read_credential; credential_problem em scripts/evaluate_openai_luna_low_live.py:46; bloqueio do supervisor antes de subprocess em scripts/luna_credential_supervisor.py:167.
Correção: Editor mascarado com asteriscos e contador só na tela, Backspace, Esc/Ctrl+U, cancelamento, limite de buffer e validação. Repetição integral de token sk- duas a quatro vezes é recusada; espaços, Unicode e controles são recusados. Nunca ler clipboard, revelar fragmentos ou dividir automaticamente a chave.
Critérios de aceite:
- [x] Colagem repetida rejeitada e corrigível
- [x] Nenhum valor real no output/status/log
- [x] Entrada inválida bloqueada antes do HTTP
- [x] Asteriscos/contador testados em console Windows com valor sintético
--- FIM ISSUE 1 ---

--- ISSUE 2 ---
[Segurança] Falhas locais, rede e JSON agrupadas no mesmo código
Labels sugeridas: security, informativa

Estado: corrigido nas fontes; rascunho não publicado.

Problema: HTTPError e ValueError eram normalizados como transport_or_response_invalid, sem subtipo suficiente para diagnóstico.
Condição: Cabeçalho local inválido, falha de conexão/timeout/protocolo ou resposta JSON inválida.
Impacto: Não distinguir falha local de falha remota; risco operacional de pedir outra chave ou repetir chamada sem causa conhecida. Não constitui, isoladamente, vulnerabilidade de autorização.
Evidência atual: scripts/evaluate_openai_luna_low_live.py:61. transport_error_code:61; response_json_invalid:209; response_shape_invalid:215. Testes MockTransport fazem exceções conterem texto sintético sensível e confirmam que ele não aparece no erro normalizado.
Correção: Classificação só pelo tipo da exceção, sem texto potencialmente secreto. Separar protocolo local, conexão, timeout, protocolo remoto, requisição local, I/O e parsing/forma do JSON. Preservar códigos HTTP 401/403/429/5xx.
Critérios de aceite:
- [x] Sem mensagem bruta de exceção/headers/body
- [x] Sem retry novo
- [x] Categorias distinguíveis em testes offline
- [x] Histórico L26 preservado, sem reclassificar sua causa
--- FIM ISSUE 2 ---

--- ISSUE 3 ---
[Segurança] Ramo de credencial vazia referenciava fase inexistente
Labels sugeridas: security, informativa

Estado: corrigido nas fontes; rascunho não publicado.

Problema: OperationPhase.AUTHENTICATION não existe no enum do contrato; o ramo de credencial vazia produzia AttributeError em vez do erro controlado.
Condição: Entrada vazia chegando diretamente ao adaptador, ou entrada malformada interceptada no novo ramo.
Impacto: Erro local sem diagnóstico contratual; nenhuma chamada necessária para reproduzir. Não comprova vazamento de credencial.
Evidência atual: scripts/evaluate_openai_luna_low_live.py:172. api/llm/contract.py:91 define as fases; scripts/evaluate_openai_luna_low_live.py:172 usa fase válida após correção.
Correção: Usar OperationPhase.VALIDATION; categoria de autenticação e códigos credential_missing/credential_input_invalid sem material secreto.
Critérios de aceite:
- [x] Entrada vazia gera erro normalizado
- [x] Sem AttributeError
- [x] Sem acesso à rede para chave inválida
--- FIM ISSUE 3 ---